

Architecture Decision Record

Title:

Selection of Cronet Variant for Post-Quantum Cryptography (PQC) Support

Date:

July 8, 2026

Status:

Proposed

Context

Our Android application requires network-level support for Post-Quantum Cryptography (PQC), specifically standards like ML-KEM (Kyber), to secure traffic against future quantum computing threats. To achieve this, we are adopting **Cronet** (the Chromium network stack).

We must decide how to distribute Cronet within the application. There are two variants available:

- **Embedded Cronet:** Compiled and bundled directly inside the application APK.
- **Non-Embedded Cronet:** A lightweight API wrapper in the APK that delegates network execution to the Cronet engine provided by Google Play Services on the user's device.

We need to select the variant that best balances strict cryptographic guarantees, application size, and maintenance overhead.

Comparison

Parameter	Option 1: Embedded	Option 2: Non-Embedded
PQC Enforcement	Guaranteed (deterministic version)	Variable (depends on user's device)
APK Size Impact	~5 MB increase	~100 KB increase
Security Updates	Manual (requires an app update)	Automatic via Google Play Services
GMS Dependency	None (runs anywhere)	Required
Fallback Logic	Not needed for network execution	Required for non-GMS devices
Resource Usage	Slightly higher baseline footprint	Optimized (shared natively with OS)

Options Considered

Option 1: Embedded Cronet (Standalone)

The app bundles the full Cronet binary and BoringSSL stack natively.

- **Pros:**

- **Deterministic Crypto:** Guarantees that 100% of our installed user base has the exact PQC capabilities we ship, regardless of their OS version or Google Play Services status.
- **Zero Version Lag:** We control the update cycle and can adopt new PQC algorithms (like finalized FIPS 203) immediately, without waiting for Google rollouts.
- **Universal Compatibility:** Works on all Android devices, including those without Google Mobile Services (GMS), such as Huawei and Amazon Fire devices.

- **Cons:**

- **Increased App Size:** Adds approximately ~5 MB to the final APK/AAB size.
- **Maintenance Burden:** Security patches for the network/TLS stack are entirely our responsibility. We must push an app update to fix any newly discovered vulnerabilities.
- **Higher Memory Footprint:** Spins up an isolated network engine, preventing resource sharing with the OS.

Option 2: Non-Embedded Cronet (Google Play Services)

The app includes a ~100 KB dependency and relies on Google Play Services to provide the network engine.

- **Pros:**

- **Lean App Size:** Negligible impact on APK size and download times.
- **Evergreen Security:** Google handles background updates to the Cronet engine, ensuring users automatically receive TLS patches and evolving PQC standards without requiring an app update.
- **Optimized Performance:** The network stack is natively shared across the device, improving memory and battery efficiency.

- **Cons:**

- **Feature Fragmentation:** PQC support depends on the user's version of Google Play Services. Devices with outdated or unpatched Play Services may not support the necessary PQC cipher suites.
- **GMS Dependency:** Fails on devices without Google Play Services.

- **Fallback Required:** Necessitates writing and maintaining fallback logic (e.g., to `URLConnection` or `OkHttp`) for non-GMS devices, which likely will not support our PQC requirements.

Decision

[Pending Team Decision]

Guidance for the final decision:

- **Select Option 1 (Embedded)** if the application requires **strict PQC enforcement** (i.e., the app must refuse connections if PQC cannot be negotiated) or targets non-GMS markets.
- **Select Option 2 (Non-Embedded)** if PQC is treated as a **progressive enhancement** (falling back to classical elliptic curve cryptography when necessary), prioritizing app size and automatic security updates.

Consequences

- **If Option 1 is chosen:** We must integrate Cronet version monitoring into our DevOps cycle to ensure we are promptly updating our dependency whenever Chromium patches a security flaw. We accept the ~5 MB size penalty.
- **If Option 2 is chosen:** We must implement graceful fallback network logic for non-GMS devices. We must also ensure our backend infrastructure allows classical cryptographic fallbacks for users with outdated Play Services.